OdontoCloud

DOC-05

# Política y Procedimientos de Seguridad de la Información

## Directrices de Ciberseguridad, Salvaguardas Criptográficas, Prevención OWASP y Gestión de Incidentes

Software Odontológico SaaS | Resolución 1995/1999 & 839/2017 | Marco Res. 3100/2019 (Vigente)

Edición Institucional 2026

⚠️ ESTADO: DOCUMENTACIÓN INSTITUCIONAL EN REVISIÓN (Borrador Oficial previo a firmas legales y validación COPNIA)

**Proveedor Tecnológico:** OdontoCloud Colombia
**Titular / Razón Social:** JUAN EDUARDO MADRID REQUENA (Persona Natural con Registro Mercantil)
**Identificación / NIT:** C.C. 1102849760 | NIT 1102849760-5 (Sujeto a verificación con RUT)
**Registro Mercantil:** Cámara de Comercio de Sincelejo — Matrícula 148131 (Activa 2026 - Sujeta a cotejo con certificado mercantil)
**Domicilio Legal:** Sincelejo, Sucre, Colombia

**Código Documental:** DOC-05
**Versión:** 2026.1 (Release 8.2)
**Fecha de Emisión:** Octubre de 2026
**Actividad Económica:** CIIU 6312 — Portales Web y Servicios de Procesamiento de Datos
**Canal Oficial:** https://odontocloudcolombia.com
**Contacto:** bienvenido@odontocloudcolombia.com

## 1. Objeto y Alcance de la Política de Seguridad

El presente documento formaliza los lineamientos, salvaguardas tecnológicas y procedimientos operativos implementados por OdontoCloud Colombia para preservar la confidencialidad, integridad, disponibilidad y trazabilidad de los datos asistenciales y administrativos gestionados a través de la plataforma SaaS.

Esta política aplica a todos los componentes de la arquitectura: servidores virtuales en nube (VPS), contenedores Docker, bases de datos PostgreSQL, pasarelas de conexión (Kong API Gateway, PostgREST), endpoints criptográficos y mecanismos de comunicación con terminales cliente en consultorios e IPS.

## 2. Salvaguardas Criptográficas (Cifrado en Reposo y en Tránsito)

OdontoCloud implementa controles criptográficos de estándar bancario y hospitalario conforme a las mejores prácticas internacionales (ISO/IEC 27001:2022 y lineamientos NIST SP 800-52):

| Dimensión Criptográfica | Estándar / Algoritmo Implementado | Aplicación Concreta en el Sistema |
|---|---|---|
| Cifrado en Tránsito (Network) | Protocolo Transport Layer Security (TLS 1.3) con suites de cifrado seguras (ECDHE-RSA-AES256-GCM-SHA384). | 100% de las comunicaciones web, API REST, WebSockets y transmisiones con MinSalud y Factus. Prohibición de HTTP plano. |
| Cifrado Simétrico en Reposo (Database) | Advanced Encryption Standard en modo Galois/Counter Mode (AES-256-GCM) con vector de 12 bytes y Auth Tag de 16 bytes. | Cifrado de credenciales de integración de cada clínica (claves APIM, secretos Entra ID y tokens). Jamás se guardan en texto plano. |
| Almacenamiento de Contraseñas | Algoritmo de hash criptográfico unidireccional con salt dinámico (Argon2id / Bcrypt, factor de coste 10+). | Protección de credenciales de acceso de doctores y personal administrativo. Imposibilidad de recuperación en texto plano. |
| Firmas Electrónicas Confiables | Resumen criptográfico SHA-256 encadenado a la clave secreta de sesión del profesional tratante. | Certificación de cierre de historias clínicas, garantizando que cualquier modificación posterior invalide el hash. |

## 3. Prevención de Vulnerabilidades (Alineación OWASP Top 10)

- Inyección SQL (SQLi): Eliminación total de concatenación de strings en sentencias SQL. Toda consulta viaja a través de la capa PostgREST con tipado estricto y prepared statements.
- Ataques de Secuencias de Comandos en Sitios Cruzados (XSS): Sanitización obligatoria del contenido HTML mediante biblioteca especializada (DOMPurify) antes de cualquier renderizado en pantalla.
- Asignación Masiva y Falsificación de Solicitudes (CSRF): Uso de tokens JWT firmados en cabeceras de autorización Bearer, prescindiendo de cookies de sesión vulnerables a CSRF.
- Rotura de Control de Acceso (BOLA / IDOR): Políticas obligatorias de Row Level Security (RLS) en el motor de base de datos PostgreSQL, impidiendo que un usuario acceda a datos de otra sede o clínica alterando IDs en la URL.

## 4. Gestión y Notificación de Incidentes de Seguridad

OdontoCloud cuenta con un protocolo formal de respuesta ante incidentes de ciberseguridad:

### 🚨 Procedimiento de Notificación a la IPS ante Incidentes (Ley 1581/2012)

En caso de detectarse un evento de seguridad comprobado que comprometa la confidencialidad de datos personales o clínicos de los pacientes (fuga de información o acceso no autorizado no mitigado): 1. Contención Inmediata: Aislamiento de sesiones y rotación inmediata de secretos en un plazo inferior a 2 horas. 2. Notificación Formal al Prestador: Comunicación escrita a la Dirección Médica de la IPS en un plazo máximo de veinticuatro (24) horas hábiles, detallando el vector de ataque, el alcance potencial y las medidas correctivas aplicadas. 3. Soporte para Reporte SIC: Suministro del informe forense para que el Prestador (como Responsable) cumpla con su deber de notificación a la Superintendencia de Industria y Comercio (SIC).

### ⚖️ Declaración de Alcance, Propiedad y Reserva Institucional

El presente documento ha sido elaborado por el equipo de ingeniería y cumplimiento de OdontoCloud Colombia como proveedor tecnológico del software. No constituye una habilitación de servicios de salud ante el REPS, ni reemplaza los dictámenes emitidos por profesionales independientes con matrícula COPNIA. La responsabilidad asistencial y de habilitación corresponde de forma indelegable al Prestador de Servicios de Salud (IPS o Profesional Independiente).

| ELABORÓ (TÉCNICO / INGENIERÍA) | REVISÓ (AUDITORÍA / COMPLIANCE) | APROBÓ (DIRECCIÓN / LEGAL) |
|---|---|---|
| **Equipo de Ingeniería y Arquitectura SaaS**<br>OdontoCloud Colombia<br>Fecha: Octubre de 2026<br>Estado: Aprobado Técnico | **Responsable Técnico de Seguridad y Sistemas**<br>[PENDIENTE DE DESIGNACIÓN: Ingeniero de Sistemas con Matrícula Profesional COPNIA]<br>**PENDIENTE DE VALIDACIÓN MATRÍCULA COPNIA** | **Dirección / Titular y Propietario**<br>JUAN EDUARDO MADRID REQUENA (Titular / Propietario)<br>C.C. 1102849760 \| NIT 1102849760-5 (Sujeto a verificación con RUT)<br>**PENDIENTE DE FIRMA PROTOCOLARIA** |


OdontoCloud © 2026. Todos los derechos reservados.